

Financial AI Regulatory Compliance Framework

FSC Financial-Sector AI Guideline (effective 2026-06-22) 7-principle alignment
Korea AI Basic Act · EU AI Act mapping · compliance architecture design

Document Type	Technical Document
Date	June 2026 (revised to reflect the guideline’s entry into force)
Version	v2.0
Applicable Regulations	FSC Financial-Sector AI Guideline (effective 2026-06-22), Korea AI Basic Act (Act No. 20676), EU AI Act, GDPR

Executive Summary — This document maps, **at the architecture level**, how the PLE-based financial AI recommendation **reference system** (Independent Research) is designed and implemented against the FSC Financial-Sector AI Guideline (effective 2026-06-22) 7 principles and adjacent regulation. It covers the guideline’s 7 principles (governance, legality, auxiliary nature, reliability, financial stability, good faith, security), the Korea AI Basic Act (effective 2026.1.22), EU AI Act (Art. 13/14/15), and GDPR Art. 22, including audit trails, fairness monitoring, drift surveillance, herding detection, kill switches, opt-out, Human-in-the-Loop, and automated governance report generation.

Nature — This is not a compliance attestation for an operating financial institution. The system has no production deployment and uses no production data, so the implementation status of each mapping is distinguished honestly in three states — **● operational / ● implemented, not yet wired / ○ absent** — with no over-claiming.

Table of Contents

Financial AI Regulatory Environment Overview	4
Korea AI Basic Act	4
FSC Financial-Sector AI Guideline — 7 Principles (effective 2026-06-22)	5
Risk-Assessment System and the AI Risk Management Framework (AI RMF)	6
Comparison with EU AI Act	6
Global Regulatory Trends Summary	7
7-Principle Mapping — Guideline Check-Items and System Response	8
Per-Principle Response Matrix (3-state honest evaluation)	8
Controls with Confirmed Operational Effect (●)	9
Implemented-but-Not-Wired (◐) and Absent (○)	9
EU AI Act Article-Level Mapping	11
Article 13: Transparency and Information Provision	11
Article 14: Human Oversight	11
Article 15: Accuracy, Robustness, and Cybersecurity	12
GDPR Article 22: Automated Decision-Making	12
Korea AI Basic Act High-Impact AI Classification and Financial Application	14
High-Impact AI Applicability Assessment	14
AI Basic Act Key Article Response Status	14
Regulatory Timeline	15
Compliance Architecture	16
Overall Structure	16
Security Controls	17
3-Layer Fallback as Regulatory Assurance	17
Audit Trail	18
Fairness Monitoring	19
Drift Surveillance	19
Herding Detection	19
Kill Switch	20
Opt-out and Consent Management	20
Data Retention Policy	22
Incident Management	22
Bedrock Data Protection Architecture	22
On-Premises Regulatory Compliance	25
Data Protection	25
Model Configuration	25
Ops/Audit Agents	26
Regulatory Compliance Comparison	26
Model Risk Management (MRM) Framework	26
Operational and Audit Agents	30
Architecture Overview	30
OpsAgent (Operational Agent)	30
AuditAgent (Audit Agent)	30
Model Selection	31

Design Principles	31
Airflow DAG Integration	31
Human-in-the-Loop Design	33
Design Principle	33
Per-Channel Human Oversight Framework	33
5 Human Intervention Points	33
Automated Governance Report Generation	35
Report Framework	35
36-Item Regulatory Compliance Auto-Check	35
3-Tier Governance Framework	36
Comprehensive Regulatory Mapping	36
Ops/Audit Agent Integration	37
Temporal Fact Store (Added 2026-04)	37

Financial AI Regulatory Environment

Overview

Korea AI Basic Act

The “**Framework Act on the Development of Artificial Intelligence and Establishment of Trust**” (Act No. 20676), passed by the National Assembly in December 2024 and promulgated on January 21, 2025, took effect on **January 22, 2026**. It is the first comprehensive AI legislation in the Asia-Pacific region and adopts a Risk-Based Approach.

Core Legal Structure

Transparency Obligations (Art. 31 / Enforcement Decree Art. 22)	High-Impact AI Verification (Art. 33 / Enforcement Decree Art. 24)
Prior notification of AI use, labeling of AI-generated content	Self-review obligation for operators
Fine up to 30 million KRW for violations	May request verification from MSIT (response within 30 days)
Safety Assurance (Art. 32 / Enforcement Decree Art. 23)	High-Impact AI Operator Duties (Art. 34 / Enforcement Decree Art. 26)
Targets ultra-large models with training compute $\geq 10^{26}$ FLOPs	Establish risk management measures, user protection (explainability),
(Recommendation models are exempt — high-impact AI classification based on usage domain applies)	Public disclosure on website, etc.

High-Impact AI and Finance

The AI Basic Act defines high-impact AI as “**artificial intelligence that significantly affects or may pose risks to human life, physical safety, or fundamental rights**” (Art. 2, Item 4). The Enforcement Decree enumerates 11 domains, explicitly including the **finance (credit/lending)** sector.

Domain	Application Examples	Finance Relevance
Healthcare	AI used in medical devices and digital medical devices	Indirect
Finance (Credit/Lending)	AI for credit scoring, loan assessment, and personal rights evaluation	Direct
Employment	AI for hiring and HR decisions	None
Public Services	Eligibility verification, administrative decision-making AI	Indirect
Nuclear/Biometric	Nuclear facilities, biometric analysis AI	Indirect

Implications for Finance

AI used in **loan assessment and credit scoring** explicitly qualifies as high-impact AI under the law. Even if a financial AI recommendation system does not directly perform lending operations, AI applications in **product recommendation, suitability assessment, and customer classification** may be designated as high-impact AI through future Enforcement Decree amendments or FSC guidelines. Therefore, proactively building a governance framework **at the level of high-impact AI** is a rational strategy.

FSC Financial-Sector AI Guideline — 7 Principles (effective 2026-06-22)

The Financial Services Commission **put into force** the “**Financial-Sector AI Guideline**” on **June 22, 2026**, consolidating and revising three predecessor guidelines (Financial-Sector AI Operating Guideline 2021, AI Development & Use Handbook 2022, AI Security Guideline 2023). Reflecting the rise of frontier and generative AI and the entry into force of the AI Basic Act, it is **self-applied** rather than legally mandated (each institution autonomously decides the scope and depth of application according to its resources, business characteristics, and service risk) and is **updated annually** after gathering financial-sector input. The covered “financial companies, etc.” include banks, insurers, card companies, and investment firms, and **explicitly include postal financial services (postal banking/insurance)**; fintechs and other non-financial companies are also covered when their AI use affects financial transactions.

1. Governance

Decision-making body (e.g., AI ethics committee) + **independent dedicated risk-management organization**

AI internal rules/manuals, comprehensive risk-assessment system

2. Legality

Prior review of applicable laws, periodic review and currency of internal rules

Compliance verified down to outsourced/external models and extraterritorial regulation

3. Auxiliary Nature

Final decision and accountability rest with staff (HITL)

For high-risk AI, kill switch and override are **mandatory**

4. Reliability

5. Financial Stability

Market herding (correlation) and third-party IT risk assessment

Backup model + post-hoc-intervention kill switch safeguards

6. Good Faith

Conflict-of-interest prevention (curbing affiliate/high-fee product steering)

Consumer protection, prior notification of AI use

7. Security

AI-specific threats (data/model poisoning, prompt injection)

External model/data verification, compensating controls when network-separation is relaxed

Source: FSC Financial-Sector AI Guideline (effective 2026-06-22)

Model performance, data quality, and fairness checks

Explainability (global and local; at SHAP level or above where legally required)

Risk-Assessment System and the AI Risk Management Framework (AI RMF)

The guideline’s governance principle (§1.3) requires, for each AI service, a comprehensive risk-assessment system of **risk identification/measurement -> mitigation -> residual-risk evaluation -> risk-grade rating**, and delegates the detail of that standard procedure to the companion document “**Financial-Sector AI Risk Management Framework (AI RMF)**.” Risk grades are classified in three tiers — **low / medium / high** — while specific score thresholds and component weights are presented as **examples** to be set according to each company’s risk appetite.

Risk-assessment system — Governance §1.3 (scores/weights are guideline examples)

Risk-grade bands (example)	Component weights (example)
risk score < 25 -> low (relaxed controls)	legality 20% · reliability 30%
25 ~ 50 -> medium (baseline control/management)	good faith 30% · security 30%
50 and above -> high (additional control/management)	If risk mitigation is not performed, residual risk is assessed at 100%
75 and above -> decision-making body reviews whether to launch	Under the AI Basic Act, high-impact AI is automatically classified as high-risk AI with reinforced controls

Implementation alignment — honest caveat

This system’s AIRiskClassifier (a 6-dimension weighted-sum risk-grade computation) and the offline promotion gate are an implementation corresponding to this risk-assessment system. However, they currently run **only at offline promotion time** rather than as continuous serving-time evaluation, and the grade-history store defaults to volatile (in-memory), so the “mitigation -> residual risk” tracking artifact is incomplete (● implemented, operationally not wired).

Comparison with EU AI Act

Category	Korea AI Basic Act	EU AI Act
Effective Date	2026. 1. 22.	High-risk AI: 2027. 12.
Classification	General/High-impact (2 tiers)	Prohibited/High-risk/Limited/Minimal (4 tiers)

Finance Applica- tion	Credit scoring/loan assessment explicit	Credit scoring/insurance pricing included
Prohibited AI	None	Social scoring, real-time remote biomet- rics, etc.
Obligated Parties	Single operator-centric standard	Entire supply chain: providers, deployers, users
Penalties	Fine up to 30M KRW	Up to 7% global revenue or 35M EUR
Approach	Promotion-oriented + self-regulation	Safety-oriented + mandatory compliance
Impact Assessment	Best-effort obligation	Legally mandatory pre-conformity assess- ment

Comparison Implications

Korea’s AI Basic Act has penalties **thousands of times lower** than the EU and relies more on self-regulation, but this is a **soft-landing strategy for the initial implementation period**. The Financial-Sector AI Guideline has a broader scope than the AI Basic Act (covering fintechs and other non-financial companies) and, under its good-faith principle, requires **prior notification of AI use in customer-facing services** such as AI-driven product recommendation and advice. Through future annual updates and detailed FSC rule-making, the level of application is expected to be progressively specified, making **proactive preparation** advantageous.

Global Regulatory Trends Summary

Global regulation of financial AI is converging in three directions.

Transparency & Ex-plainability

Expanding AI disclosure obligations
Requiring decision ratio-
nale explanations
Guaranteeing right to
refuse automated decisions

Fairness & Non-dis-crimination

Quantitative bias measure-
ment by protected attrib-
utes
Market herding and con-
flict of interest prevention
Mandating periodic fair-
ness audits

Safety & Account-ability

Risk-based classification
(high-risk AI)
Mandatory emergency
shutdown mechanisms
Audit trail retention oblig-
ations

7-Principle Mapping — Guideline Check-Items and System Response

For the core check-items of the Financial-Sector AI Guideline’s 7 principles, we map the implementation artifacts of the PLE-based recommendation **reference system** and their **operational wiring state**. The evaluation criterion is “operational effect” — even when a module exists, if it is not invoked on the actual deployment path it is classified as ●. (Per-item caveats match the outreach/05_fsc_supplementary self-check material.)

Per-Principle Response Matrix (3-state honest evaluation)

Principle	Guideline core check-items	System implementation artifacts	Status
① Governance	Decision-making body, independent dedicated risk-management org, AI internal rules, comprehensive risk-assessment system (low/medium/high)	Risk-grade classifier (6-dim weighted sum), offline promotion gate, governance report generator	● ○
② Legality	Prior review and currency of applicable laws, compliance for outsourced models and extraterritorial regulation	36-item law-to-function mapping catalog (AI Basic Act, PIPA, Financial Consumer Protection Act, Credit Information Act §36-2, EU AI Act, SR 11-7), regulatory auto-checker (fail-closed when evidence is absent)	● ○
③ Auxiliary Nature	Final accountability with staff (HITL), differentiated human intervention, kill switch/override mandatory for high-risk	Offline promotion human gate (auto_promote=false + HMAC audit), human review queue (per tier), human fallback router	● ● ○
④ Reliability	Model performance, data quality, fairness (Parity); explainability (global/local, at SHAP level or above where legally required)	Training performance metrics (AUC/F1/MAE), distillation data-quality gate, fairness monitor (DI/SPD/EOD), attribution (CEH · IG) and OOD detection	● ●
⑤ Financial Stability	Market herding (correlation) impact assessment, backup model + post-hoc kill switch, third-party IT risk	Block of unattended offline auto-promotion, kill switch (global/per-task/per-cluster), drift (PSI) and concentration metrics, incident reporter	● ● ○
⑥ Good Faith	Conflict-of-interest prevention and oversight mechanisms, financial-consumer protection	Suitability filter (Financial Consumer Protection Act §17, fail-closed when not assessed), contact protection (nighttime/DNC consent)	● ○

⑦ Security	AI-specific threats and attack detection, asset protection, external model/data verification	Inbound PII one-way hash (SHA256+salt), AI security checker (prompt injection), external artifact integrity verification (sha256 sidecar, safe load)	● ●
-------------------	--	--	-----

● operational (code path confirmed) ● implemented, operationally not wired ○ absent / organizational-process domain

Note: where several states are shown for one principle, it means that operational, not-wired, and absent are mixed across its check-items (e.g., ③ Auxiliary Nature — the offline promotion human gate is ●, the HITL queue is ●, staff training is ○). This evaluation reflects the 2026-06 code audit and the guideline-alignment fixes (10 fail-open/wiring gaps).

Controls with Confirmed Operational Effect (●)

Only controls whose actual execution is confirmed by a code path.

- **Training-time performance metrics** (④ Reliability) — inlined into the SageMaker training container body, executed on every training run. Aggregated separately by task type (binary AUC, multiclass F1-macro, regression MAE/RMSE).
- **Block-on-failure distillation data-quality gate** (④ Reliability) — on the distillation path, sub-threshold quality actually halts the pipeline (raises an exception). Limited to the distillation path, not the main training path.
- **Block of unattended offline auto-promotion** (③ · ⑤) — `auto_promote=false` is enforced, so nothing is promoted without an operator's explicit approval (signature). Every promotion decision is recorded with its reason and trigger in an HMAC audit log. *Honest caveat* — the automated deployment orchestration (Step Functions) path is currently **bypassed** into auto-promotion, a known gap requiring the two paths to be reconciled.
- **Inbound PII one-way hash** (⑦ Security) — on the data-ingestion path, a SHA256(salt+value) one-way hash is actually invoked. *Caveat* — there is a fail-open point that proceeds with an empty salt when none is injected, so a deploy-time gate confirming the secret is present is needed.
- **Prediction-log integrity and right to refuse automated decisions** (⑤ · ②) — a prediction-log HMAC hash chain plus an opt-out hook for automated-decision refusal (PIPA §37-2 / GDPR Art. 22 by analogy) are wired into serving.

Implemented-but-Not-Wired (●) and Absent (○)

Items whose modules and logic are complete but whose serving, data-pipeline, or schedule wiring is incomplete (●), and items not evidenced in code or in the organizational-process domain (○).

- **Comprehensive risk-assessment system, regulatory auto-checker, governance report** (① · ②, ●) — risk-grade computation (6-dim weighted sum), regulatory checker (hardened to fail-closed when evidence is absent), report generator are implemented. But serving entry points are unwired and the grade-history store defaults to volatile (in-memory).
- **Fairness and explainability** (④, ●) — DI/SPD/EOD (corresponding to the guideline's Parity metrics), an intersectional protected-attribute analyzer, and per-prediction attribution (CEH), integrated gradients (IG), and z-space Mahalanobis OOD are implemented. Serving-surface exposure of the IG artifact is complete down to the consumer wiring; the producer/loader remains. But the prediction log does not load protected attributes or outcome labels, so the evaluation data is empty.
- **Kill switch, drift/concentration, human review queue, suitability/contact protection** (③ · ⑤ · ⑥, ●) — the 3-tier kill switch, PSI drift, concentration metrics, and HITL queue/fallback router

are complete. But the deployment serving path (handler migration) and the unattended schedule (default DISABLED) wiring are incomplete. Financial Consumer Protection Act §17 suitability is inverted to fail-closed so unassessed customers are blocked (effective blocking depends on serving-context injection).

- **External model/data integrity verification** (⑦, ●) — sha256 sidecar, verifying load, and safe tar extraction (traversal blocked) are newly added. Wired into checkpoint save and the register lambda; a blanket `weights_only=True` switchover remains staged. (Directly tied to the guideline security principle §7.4 external model/data verification.)
- **Governance bodies, internal rules, staff training** (① · ③, ○) — the AI ethics committee, independent dedicated risk-management org, operating internal rules and business manuals, and staff AI-risk training are organizational-process matters not evidenceable in code.
- **Conflict-of-interest prevention and oversight mechanisms** (⑥, ○) — conflict-of-interest controls such as fee/incentive alignment checks and affiliate/house-product bias guards are absent from the code (concentration metrics are not a conflict-of-interest control).
- **Third-party IT risk governance** (⑤, ○) — dedicated procedures for vendor SLAs, cloud single-dependency alternative paths, and model-provider concentration-risk assessment are absent.

EU AI Act Article-Level Mapping

The EU AI Act is likely to classify financial AI recommendation systems as **high-risk AI** (Annex III, 5(b): credit scoring/insurance pricing). The following maps system responses to key articles.

Article 13: Transparency and Information Provision

Art. 13 Requirements and System Response

Art. 13 Requirement	System Response
Notify use of high-risk AI	AI disclosure centralized management + per-segment notification separation All recommendation outputs automatically include AI usage labeling
Explain system operation	2-Layer recommendation rationale (L1 Template + L2 LLM) 3-Agent pipeline (Feature Selector → Reason Generator → Safety Gate)
Disclose input data specification	Feature schema auto-documentation (1211D model input / 403D post-Phase-0 raw columns / 734D full-bank design) Training data source, scope, and pseudonymization status recorded
Disclose performance level	Model card auto-generation (architecture, performance, feature importance) Per-task independent metric tracking (12 tasks: avg_auc binary / avg_f1_macro multiclass / avg_mae regression)
Log generation obligation	HMAC + hash chain audit log (S3 Object Lock WORM) Full recommendation history Parquet archiving

Article 14: Human Oversight

Art. 14 Requirements and System Response

Art. 14 Requirement	System Response
Provide interface for humans to oversee AI system	Offline: Staff screen shows recommendation list + rationale; final recommendation is staff judgment Online: AI operations team directly controls recommendation direction, targets, and exclusion lists
Ensure ability to intervene and halt system	Kill Switch 3-tier (GLOBAL/PER_TASK/PER_CLUSTER) Auto-switch to conservative mode on drift detection

Right to refuse automated decisions + alternative pathway	Opt-out registration/withdrawal/confirmation + 3-tier human re-processing routing (P1 urgent 1h / P2 4h / P3 24h SLA)
---	--

Article 15: Accuracy, Robustness, and Cybersecurity

Art. 15 Requirements and System Response

Art. 15 Requirement	System Response
Achieve and maintain appropriate accuracy levels	Champion-Challenger automatic model competition PSI-based drift detection + auto-retraining on 3 consecutive critical days
Robustness against errors and faults	Ablation-based per-component contribution quantification Distilled LGBM fallback (auto-switch on teacher performance anomaly)
Cybersecurity threat response	Prompt injection defense 8 patterns (5 severity levels) Model integrity SHA-256 verification Input validation (format + size limits)
Bias prevention measures	DI/SPD/EOD 3-metric fairness auto-measurement 5 protected attributes continuous monitoring Auto-incident creation on threshold violation

GDPR Article 22: Automated Decision-Making

GDPR Art. 22 and Related Provisions Response

GDPR Art. 22 grants data subjects the right to refuse “**decisions based solely on automated processing, including profiling.**” Korea’s Personal Information Protection Act Art. 37-2 guarantees the same right.

GDPR Requirement	System Response
Right to refuse automated decisions (Art. 22(1))	Opt-out registration/withdrawal/confirmation full lifecycle management Immediate switch to human alternative pathway upon refusal
Right to request human intervention (Art. 22(3))	Human reprocessing routing (auto-counselor switch for 7 reason categories) P1/P2/P3 SLA management
Profiling information provision (Art. 13(2)(f))	Decision criteria auto-documentation (30+ filter reasons with explanations) Feature reverse mapping + per-task interpretation

Right to erasure (Art. 17)	30-day PII retention policy + encrypted deletion S3 Lifecycle auto-applied
Data subject rights audit (Art. 30)	Among 7 audit tables: profiling_audit, opt_out_audit, consent_audit DynamoDB serverless management + TTL auto-cleanup

Korea AI Basic Act High-Impact AI Classification and Financial Application

High-Impact AI Applicability Assessment

Under current law, financial product recommendation systems are **not subject to explicit high-impact AI classification as they do not constitute loan assessment**. However, expanded designation is possible under the following scenarios.

Scenario	Likelihood	Basis
Enforcement Decree amendment to include all financial product recommendations	Medium	EU AI Act already covers this scope
Customer classification/segmentation interpreted as rights evaluation	Low-Medium	Similar structure to investment suitability assessment
Business expansion to insurance product recommendations	High	Insurance pricing is EU high-risk and domestic high-impact in both frameworks
Discriminatory benefits based on churn prediction	Medium	Directly linked to fairness issues
Guideline annual update separately regulating recommendation AI	Medium	The in-force guideline only cites loan assessment as a high-impact example; separate rules for recommendation AI are unspecified — watch the annual-update trajectory

Response Strategy

While not currently subject to direct high-impact AI classification, considering the **direction of the regulatory environment**, proactively building a governance framework at **virtually the same level as high-impact AI** is a rational strategy. This not only minimizes regulatory risk but also provides an immediately deployable foundation for future business expansion (insurance, fund recommendations, etc.).

AI Basic Act Key Article Response Status

Requirement	Basis	Implementation artifact / wiring state	Status
Prior notification of AI use	Art. 31	AI disclosure module, per-segment notification separation (serving wiring depends on handler migration)	●

Labeling of AI-generated content	Art. 31	AI-generation labeling logic in recommendation rationale text	●
Risk management measures implementation	Art. 32	Kill Switch (3-tier) + eligibility/suitability verification 1. drift detection (modules complete, deployment wiring incomplete)	●
High-impact AI applicability check	Art. 33	Self-analysis of per-scenario applicability (document)	●
Risk management and user protection	Art. 34	Safety/trust document + model card generation 3-stage recommendation rationale pipeline	●
Impact assessment execution	Art. 35	KoreanFRIAAssessor (7-dimension) implemented; periodic-execution process needs organizational establishment	●
Right to refuse automated decisions	PIPA Art. 37-2	Opt-out hook wired into serving + human reprocessing routing	●
Governance framework establishment	7 Principles	3-tier framework designed; formal committee establishment is an organizational decision	○

● operational ● implemented, operationally not wired ○ absent / organizational decision

Regulatory Timeline

Key Regulatory Dates

Date	Event
2025. 1. 21	AI Basic Act promulgation
2025. 08	AI Basic Act Enforcement Decree pre-announcement
2025. 12. 22	FSC AI Council — guideline draft released for comment
2026. 01. 22	AI Basic Act effective
2026. 06. 22	Financial-Sector AI Guideline effective (with companion AI RMF and security handbook)
Annual	Guideline update (gathering financial-sector input)
2027. 01 (est.)	AI Basic Act fines enforcement begins
2027. 12	EU AI Act high-risk AI provisions fully applicable

Compliance Architecture

Overall Structure

The regulatory compliance infrastructure is organized in 3 layers.

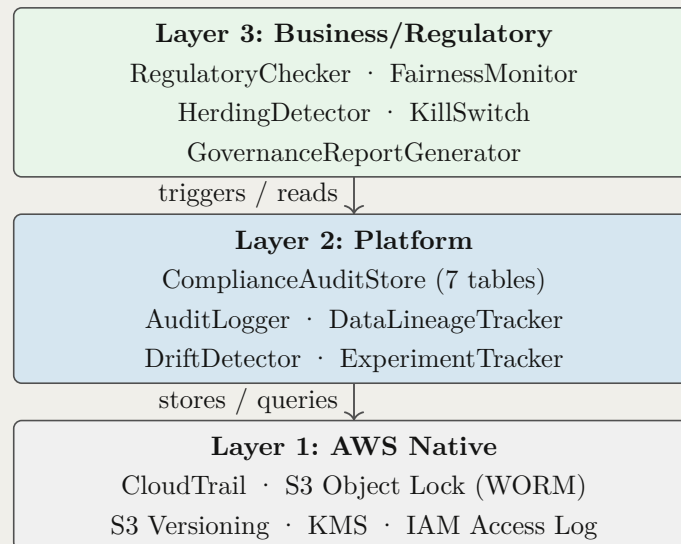


Figure 1: 3-layer compliance architecture. Layer 3 enforces business rules; Layer 2 manages platform-level audit state; Layer 1 provides immutable AWS-native guarantees.

Layer 1: AWS Native (Automatic, No Additional Cost)

- **CloudTrail** -> All AWS API calls automatically recorded
- **S3 Versioning** -> Data/model change history preserved
- **S3 Object Lock** -> Audit log immutability (WORM)
- **KMS** -> Encryption key management + key usage audit
- **IAM Access Log** -> Resource access audit

Layer 2: Platform Level (Semi-automatic)

- **ComplianceAuditStore** -> 7 audit tables (DynamoDB)
- **AuditLogger** -> HMAC + hash chain (S3 + DynamoDB)
- **DataLineageTracker** -> Feature-to-source tracing (S3 metadata)
- **ExperimentTracker** -> Experiment metrics (SageMaker Experiments)
- **DriftDetector** -> PSI monitoring (SageMaker Model Monitor)

Layer 3: Business/Regulatory Level (Explicit)

- **RegulatoryComplianceChecker** -> 36-item auto-check

- **FairnessMonitor** -> DI/SPD/EOD protected attribute monitoring (batch evaluation per cycle)
- **HerdingDetector** -> Systemic risk herding detection
- **IncidentReporter** -> Auto-report by severity
- **GovernanceReportGenerator** -> Monthly/quarterly governance reports (auto-generated per cycle)
- **KillSwitch** -> Emergency model deactivation
- **ComplianceAuditStore** -> Logs every prediction with full compliance context
- **ConsentManager** -> Marketing consent lifecycle (grant/revoke/renew/verify)
- **AIOptOut** -> AI decision refusal registration, withdrawal, confirmation
- **ProfilingRights** -> Data subject rights exercise (access/correction/deletion/portability)

Security Controls

PII Protection and LLM Security

PII Masking in Serving: Customer PII (name, account number, resident registration number) is masked before entering the recommendation reason generation pipeline. Only anonymized tokens are passed to the LLM layer, structurally preventing PII leakage to external model providers.

PromptSanitizer for LLM Calls: All prompts passed to Bedrock (Claude Haiku) are pre-processed by **PromptSanitizer**, which strips 8 injection patterns (4 Korean + 4 English) and validates prompt structure before the API call. This is architecturally consistent with FSC Principle 7 (Security) and AI Basic Act Art. 34 (risk management).

Structural separation: The compliance module (ConsentManager, AIOptOut, RegulatoryChecker, ProfilingRights) operates independently from the scoring and reason-generation path. Compliance checks are enforced as pre-flight gates — a prediction is only served if all compliance conditions are satisfied.

3-Layer Fallback as Regulatory Assurance

The 3-layer fallback architecture ensures that service never completely stops — corresponding to the core requirement of the guideline’s financial-stability principle §5.2 (use of a backup model + a post-hoc-intervention kill switch).

Layer	Mechanism	When Active
Layer 1 (Primary)	Distilled LGBM Student via Lambda + FallbackRouter	Normal operation
Layer 2 (Failover)	Direct PLE Teacher inference (SageMaker Endpoint)	Student degraded or unavailable
Layer 3 (Safety Net)	Rule-based engine: 12-task rules + Financial DNA routing	Both model layers unavailable

Regulatory significance: Even under CRITICAL kill-switch activation, Layer 3 guarantees customers receive rule-based product guidance — preventing a complete service blackout. All three layers produce `contributing_features` for explanation compliance.

CloudFormation DynamoDB Compliance Tables

The following DynamoDB tables are provisioned via CloudFormation for compliance state management:

- `consent-store`: Marketing consent records (grant/revoke/renew/channel)
- `opt-out-store`: AI decision refusal history per customer
- `profiling-rights-store`: Data subject rights exercise records
- `audit-store`: Per-prediction compliance audit log (ComplianceAuditStore)

All tables use TTL auto-cleanup aligned with the 7-year retention policy.

Audit Trail

Immutable Logs — HMAC + Hash Chain

Each audit log entry is signed with HMAC-SHA256, and consecutive entries are linked via SHA256 hash chain (`prev_hash`) to prevent tampering.

On-Prem	AWS
Local JSONL + HMAC + hash chain	S3 Object Lock (WORM) + HMAC + hash chain

AWS Reinforcement:

- S3 Object Lock: Physical deletion blocked at AWS level (even administrators cannot delete)
- KMS encryption: Audit logs themselves are encrypted
- CloudTrail: Access to audit logs is also audited (meta-audit)

7 Regulatory Audit Tables

DynamoDB-based serverless management (auto-scaling, per-item TTL):

Table	Purpose	Retention
<code>ks_audit</code>	Kill switch activation/deactivation history	7 years
<code>consent_audit</code>	Marketing consent change history (grant/revoke/renew)	7 years
<code>profiling_audit</code>	Data subject rights exercise (access/correction/deletion/restriction/portability)	7 years
<code>opt_out_audit</code>	AI decision refusal history	7 years
<code>incident_audit</code>	Regulatory incidents (by severity)	7 years
<code>distillation_audit</code>	Teacher-student model performance gap	3 years
<code>embedding_audit</code>	Embedding quality metrics	3 years

Fairness Monitoring

3 fairness metrics are continuously monitored across 5 protected attributes.

Note on income: **income** is an input feature and a protected attribute monitored for fairness bias. It is *not* a model task. The deterministic bucket derivation **income_tier** was removed from tasks (13-task set, v14 → v13 reduction) due to leakage — the model could trivially reconstruct the label from the feature. Similarly, **tenure_stage**, **spend_level**, and **engagement_score** were removed as deterministic transformations of inputs. The income *feature* itself is retained and monitored.

Protected Attributes

- **Age group:** youth / middle / pre_senior / senior
- **Gender:** M / F / unspecified
- **Region type:** metropolitan / urban / rural
- **Income quintile:** low / middle / high (feature, not task)
- **Lifecycle:** 6 classes

Thresholds and Actions

- **DI (Disparate Impact):** 0.8 1.25
- **SPD (Statistical Parity Difference):** $|\text{SPD}| \leq 0.1$
- **EOD (Equal Opportunity Difference):** $|\text{EOD}| \leq 0.1$

DI < 0.6 -> CRITICAL incident

DI < 0.8 -> MAJOR incident

$|\text{SPD}| > 0.1$ -> MINOR incident

Drift Surveillance

Combines SageMaker Model Monitor (default) + custom PSI (extended).

Metric	Threshold	Auto Action
PSI (warning)	0.1	Warning logging
PSI (critical)	0.25	Alert responsible party
3 consecutive critical days	–	Auto-retraining trigger (Step Functions)

Per-feature individual PSI is tracked, enabling early detection of sudden changes in specific features even when the overall distribution appears stable.

Herding Detection

Prevents **systemic risk** from excessive recommendation concentration on the same products.

Metric	Description	Severity Classification
HHI	Herfindahl-Hirschman Index — market concentration	none -> low -> medium
Gini coefficient	Recommendation inequality measurement	-> high -> critical
Entropy	Recommendation diversity measurement	

Herding rate	Proportion of most-recommended product	Kill switch review on critical
--------------	--	--------------------------------

Kill Switch

3-tier emergency model deactivation system.

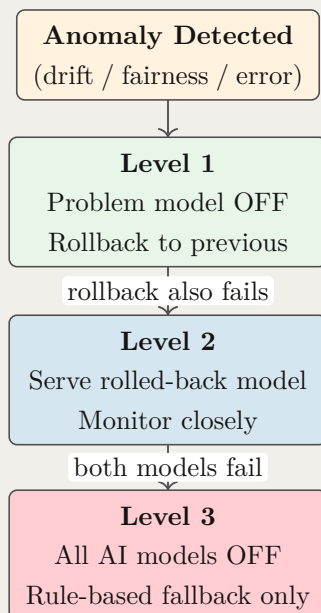


Figure 2: Kill switch escalation: 3-level cascade with automatic fallback. Service never fully stops.

Kill Switch Structure

GLOBAL

Full model deactivation
State stored in DynamoDB
Checked on every request

PER_TASK

Specific task only deactivated
(e.g., click, purchase)
Only that task falls back

PER_CLUSTER

Specific customer segment only
(e.g., cluster_5)
Only that cluster falls back

Fallback strategies: Rule-based recommendations / previous model rollback / recommendation deactivation (choose one)

Opt-out and Consent Management

Feature	Description
AI decision refusal registration	Opt-out registration -> immediate switch to human alternative pathway
Refusal withdrawal	Previous opt-out withdrawn -> AI recommendation reactivated
Marketing consent management	Grant/revoke/renew history tracking, per-channel and per-purpose opt-in verification
Nighttime SMS blocking	Auto-filtering by marketing consent status + time zone

Audit trail	All consent changes and refusal history recorded in consent_audit, opt_out_audit
-------------	--

Data Retention Policy

Automatically applied via S3 Lifecycle Rules.

Category	Retention	Action	Regulatory Basis
Raw Data	30 days	Delete	GDPR minimization principle
Processed Features	90 days	Glacier archive	Retraining support
Training Data	365 days	Glacier archive	Reproducibility assurance
Model Checkpoints	365 days	Retain	Rollback support
Inference Results	90 days	Delete	Dispute response
Audit Logs	2,555 days (7 years)	Immutable retention (WORM)	Financial regulation 7-year retention
PII Data	30 days	Encrypted deletion	GDPR Art. 17 right to erasure

Incident Management

Automated classification and response system by severity.

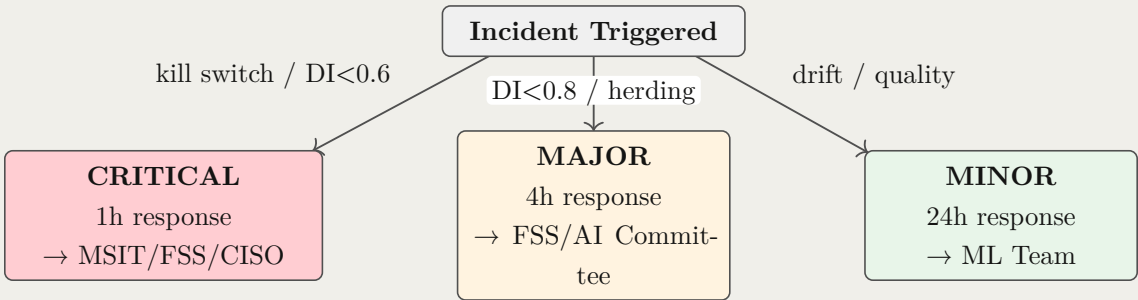


Figure 3: Incident severity classification with differentiated response SLAs and escalation targets.

Severity	Response Time	Trigger	Report To
CRITICAL	1 hour	Kill switch activation, DI<0.6, security breach	MSIT/FSS/CISO
MAJOR	4 hours	DI<0.8, herding critical, model rollback	FSS/AI Committee
MINOR	24 hours	Drift warning, quality degradation, herding high	ML Team

Bedrock Data Protection Architecture

The most critical regulatory issue when leveraging LLMs in financial AI systems is the prevention of customer data leakage. Amazon Bedrock addresses this through five structural safeguards:

Safeguard	Details
No Data Training	Input/output data is never transmitted to model providers (Anthropic, Meta, etc.) and is never used for model retraining (including fine-tuning). AWS guarantees this contractually in its Terms of Service.
Transit Encryption	TLS 1.2+ encryption protects data in transit.
VPC PrivateLink	Bedrock API is invoked through VPC-internal endpoints without traversing the public internet. Customer data is never exposed to public networks.
In-Region Processing	All inference is processed in the ap-northeast-2 (Seoul) Region. Customer data never leaves Korea.
CloudTrail Audit	Every Bedrock API call (InvokeModel, Converse, etc.) is automatically recorded in CloudTrail. Complete audit trail of who called which model when.

Regulatory Mapping

Regulation	Requirement	Bedrock Compliance
PIPA (Korea)	Third-party provision vs. delegated processing	Bedrock constitutes delegated processing within AWS infrastructure. Data is not transmitted to model providers, thus not third-party provision.
PIPA (Korea)	Cross-border transfer restriction	In-region processing in ap-northeast-2. No cross-border transfer occurs.
Financial-Sector AI Guideline	Data governance	CloudTrail audit logs + VPC isolation + transit encryption enable complete data flow tracking.
EU AI Act Art.10	Data governance	No-training-use guarantee. Inference data processing location documented.
AI Basic Act (Korea)	High-impact AI data management	HMAC audit logs and CloudTrail dual-recording prove data processing history.

Data Flow Diagram

Data flow during recommendation reason generation and agent diagnostics:

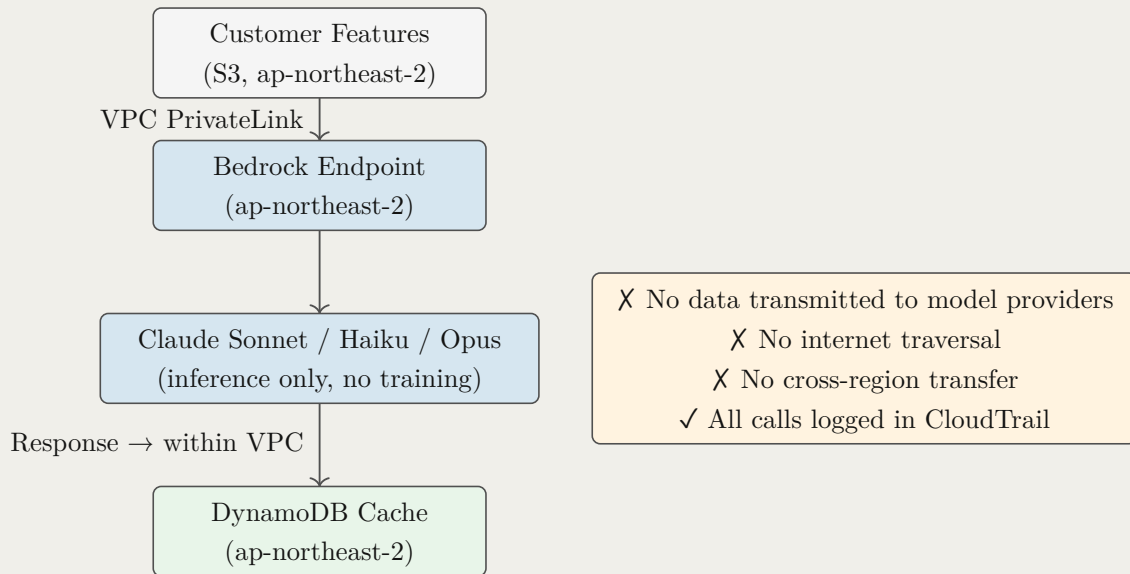


Figure 4: AWS Bedrock data flow: processed via VPC PrivateLink with no cross-region data transfer.

On-Premises Regulatory Compliance

Air-gapped on-premises environments are **structurally stronger** than cloud deployments from a data protection perspective, as external network access is architecturally impossible.

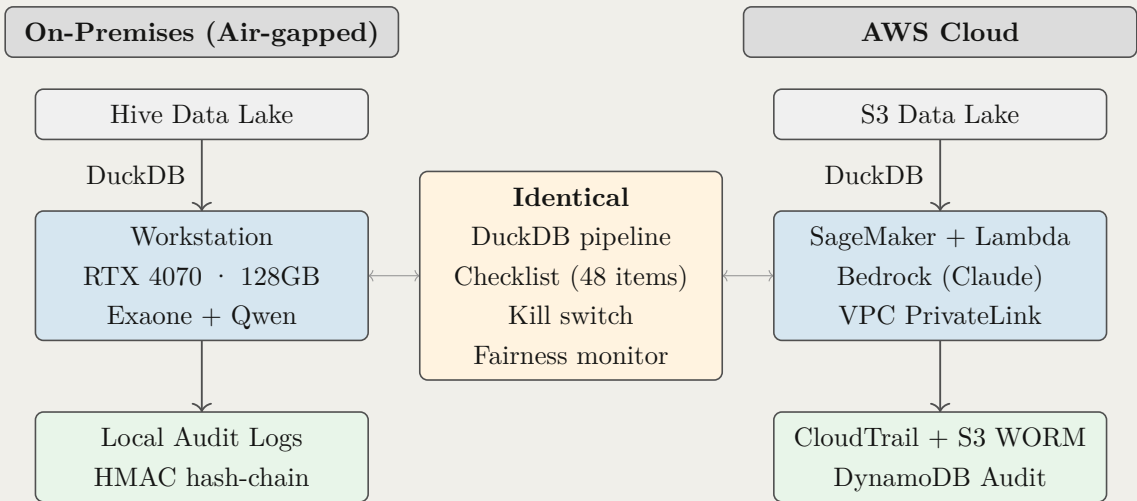


Figure 5: On-premises vs AWS: identical DuckDB pipeline and compliance framework, different infrastructure layers.

Data Protection

Item	On-Premises	AWS (Bedrock)
External data transfer	Impossible — air-gapped	In-region via VPC PrivateLink
Model provider data access	N/A — local open-source models	Contractually prohibited by Bedrock ToS
Audit trail	Local HMAC hash-chain (JSONL)	S3 Object Lock + CloudTrail
Cross-border transfer	Cannot occur	Processed within ap-northeast-2

Model Configuration

All on-premises models are open-source:

Purpose	Model	License & Notes
Reason generation/critique	Exaone 3.5 7.8B	Apache 2.0 (LG AI Research). Korean-specialized.
Agent consensus	Qwen 2.5 14B Q4	Apache 2.0 (Alibaba). Logical reasoning.
Embeddings	all-MiniLM-L6-v2	Apache 2.0 (sentence-transformers).

Sequential loading on RTX 4070 (12GB VRAM). Zero vendor lock-in; model replacement requires only config changes.

Ops/Audit Agents

On-premises agents use the **same rule engine, checklist, and tool catalog** as AWS. Differences:

Feature	On-Premises	AWS
Checklist evaluation	Identical (48 items)	Identical
Consensus mechanism	2-Round hybrid (Qwen 14B × 5+2)	Independent voting (Bedrock Claude Sonnet 4.6 × 3, run sequentially / parallel=False). Unanimous PASS required; any dissent → WARN + minority_report preserved
Minority report	Identical — locked at Round 1	Identical — all dissent preserved
Operator dialog	Not available — structured reports only	Sonnet Tool Use conversation
Case store	Identical (LanceDB)	Identical
Notifications	Email/Slack	SNS + Slack

Regulatory Compliance Comparison

Requirement	On-Premises	AWS
PIPA cross-border transfer	Impossible (air-gapped)	In-region processing
FSS data governance	Local HMAC audit logs	CloudTrail + S3 Object Lock
EU AI Act human oversight	Agent recommendation + human decision (same)	Same + dialog interface
AI Basic Act kill switch	Local kill switch (same)	DynamoDB kill switch
Explainability	IG-based reasons + Exaone rewrite	IG-based reasons + Claude Sonnet rewrite

On-premises lacks conversational agent capabilities but offers structurally perfect data protection. From a regulatory perspective, “customer data never leaves the premises” is the strongest possible safeguard.

Model Risk Management (MRM) Framework

Full-lifecycle model governance aligned with **SR 11-7** (Federal Reserve/OCC), **EBA ML Guidelines**, **NIST AI RMF 1.0**, and the **Financial-Sector AI RMF** (delegated by the guideline).

MRM Lifecycle

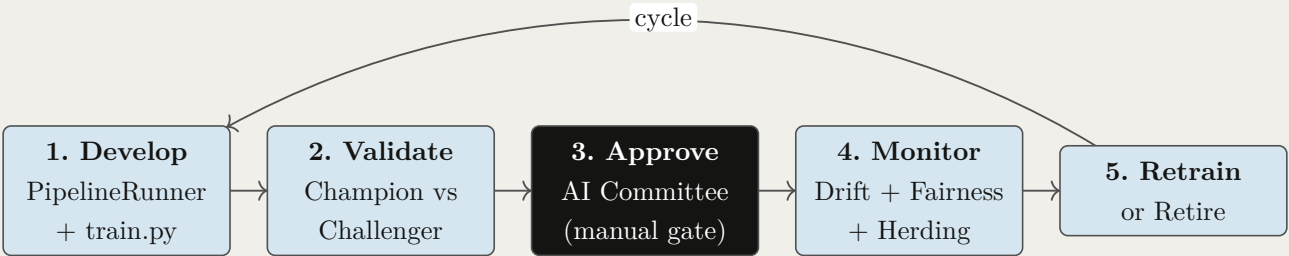


Figure 6: MRM lifecycle: 5-stage cycle aligned with SR 11-7, NIST AI RMF, and the Financial-Sector AI RMF. Stage 3 (Approve) is always manual.

Development → Validation → Approval → Monitoring → Retrain / Retire

Stage	Activity	System Component
Development	Feature engineering, model training, of-line evaluation	PipelineRunner (Phase 0) + train.py (Phase 1)
Validation	Champion-Challenger comparison, ablation, fairness audit	ModelCompetitionManager + FairnessMonitor
Approval	Manual review gate — <code>auto_promote = false</code>	AI Committee sign-off (Human-in-the-Loop)
Monitoring	Drift, performance, fairness, herding — continuous	DriftDetector + PerformanceMonitor + FairnessMonitor
Retrain / Retire	Triggered retrain or model decommission	ConsecutiveDriftTracker → dag_monthly_retrain

Model Inventory

Model Registry

Every model version is recorded in `ModelCompetitionManager.model_registry` with:

- **Model ID, version, training date, dataset snapshot hash**
- **Architecture config** (expert count, task groups, adaTT strengths)
- **Validation metrics** (per-task AUC/F1/MAPE, calibration, fairness DI/SPD/EOD)
- **Approval status** (pending / approved / rejected / retired)
- **Lineage** — which champion it replaced and why

Independent Validation (Champion-Challenger)

SR 11-7 Pillar 2 — Independent Model Validation

Gate policy: `auto_promote = false` — no model enters production without explicit human approval.

Comparison criteria:

1. Per-task AUC / F1 / MAPE (absolute performance)
2. Paired *t*-test across temporal folds (statistical significance)
3. Calibration: predicted probability vs. observed frequency
4. Fairness: Disparate Impact (DI > 0.8), SPD, EOD
5. Inference latency and cost efficiency

Decision flow: Challenger trained → metrics collected → report generated → AI Committee reviews → promote / reject / request re-experiment.

Continuous Monitoring → Retrain Trigger

Monitor	Trigger Condition	Action
DriftDetector (PSI)	Feature or prediction PSI > 0.25	Alert (Orange)
ConsecutiveDriftTracker	3 consecutive days of critical drift	Auto-trigger <code>dag_monthly_retrain</code>
FairnessMonitor	DI < 0.8 or SPD/EOD threshold breach	Alert → AI Committee review
PerformanceMonitor	Task AUC below Yellow threshold	Alert → retrain evaluation

After retraining completes, the newly trained model is registered via `ModelRegistry.package`. The offline Champion-Challenger gate (`ModelCompetition.evaluate` with a fidelity safety floor) then auto-decides promotion: it is approved iff the primary metric improves by `min_improvement` (default 0.5%), no secondary metric degrades beyond `max_degradation` (default 2%), and no fidelity failures remain. Every decision — `bootstrap`, `promote`, `reject`, or `force_promote` — is written by `AuditLogger.log_model_promotion` to an HMAC-signed, hash-chained S3 WORM log. `--force-promote` is reserved for operator override (bootstrap or emergency rollback).

Emergency Response (Kill Switch)

When monitoring detects a critical failure, the 3-tier Kill Switch provides immediate response:

1. **Deactivate** — model serving is halted (global / per-task / per-cluster granularity)
2. **Rollback** — previous approved model version is restored from the registry
3. **Fallback** — rule-based recommendation engine takes over until a validated model is re-deployed

All kill-switch activations are logged as CRITICAL incidents and reported to MSIT/FSS/CISO within 1 hour per the Incident Management protocol above.

Operational and Audit Agents

Architecture Overview

The serving agents (L1 Rule / L2a Retrieval / L2b Generation) reside on the real-time recommendation path. The **OpsAgent** and **AuditAgent** described here are fully separate **batch-only** agents that share no state with the serving path. They execute exclusively as downstream tasks within Airflow DAGs. This separation ensures regulatory surveillance functions do not impact real-time serving SLAs.

OpsAgent (Operational Agent)

Trigger and Input

Trigger: dag_drift_monitoring completion, training Job completion event

Input data:

- eval_metrics.json: per-task AUC/F1/MAPE, calibration metrics
- Training logs: per-task loss trajectory, gradient norm history
- Gate entropy: expert routing skew (MoE gate softmax distribution)
- PSI drift reports: feature/prediction/label distribution changes

Processing pipeline: JSON parsing → anomaly detection rules (threshold-based pre-filtering) → on anomaly detection, forward structured prompt to LLM.

Prompt example

“Analyze the following eval_metrics.json and gate entropy. Report (1) tasks with degraded performance, (2) gate skew (experts with entropy < 0.3), (3) features exceeding PSI threshold, (4) recommended actions in structured format.”

Output: Model health report (Markdown) — stored at S3 governance/ops_reports/. On anomaly detection, alerts are sent via Slack channel and email.

AuditAgent (Audit Agent)

Trigger and Input

Trigger: dag_fairness_monitoring completion, quarterly governance cycle (dag_governance_quarterly)

Input data:

- FairnessMonitor report: DI/SPD/EOD (5 protected attributes × per-task)
- Audit trail integrity verification: HMAC hash chain validation status
- Opt-out statistics: request count, processing rate, avg. processing time by period
- Governance checklist: 36-item auto-check results

Processing pipeline: automated comparison against regulatory thresholds ($DI \geq 0.8$, $|SPD| \leq 0.1$, $|EOD| \leq 0.1$) $\rightarrow$ violation extraction $\rightarrow$ request LLM to summarize violations and recommend actions.

Prompt example

“Compare the following fairness metrics against internal fairness thresholds ($DI \geq 0.8$, $|SPD| \leq 0.1$, $|EOD| \leq 0.1$ — mapping to the guideline’s Reliability-principle Parity metrics). Report (1) violations (protected attribute, task, metric value), (2) severity (P1/P2/P3), (3) recommended actions.”

Output: Regulatory compliance report (Markdown) — stored at S3 `governance/audit_reports/`. Alerts dispatched by priority: P1 (immediate escalation), P2 (review within 24h), P3 (included in quarterly report).

Model Selection

Environment	Model	Rationale
Air-gapped (on-prem)	Exaone 3.5 7.8B (reason gen.) + Qwen 2.5 14B Q4 (agent consensus)	Apache 2.0 open-source. Sequential loading on RTX 4070.
Cloud (AWS)	Claude Haiku 4.5 API	Cost-efficient (\$0.25/1M input), reliable structured output

Cost estimate: 1–2 calls per batch yields approximately \$0.01/day. Input consists of JSON metrics (a few KB) + prompt, so token consumption is minimal.

Design Principles

Automation scope

- Batch-only:** does not intervene in real-time serving path
- Structured judgments:** threshold comparison, trend analysis, violation classification are handled by the agent
- Unstructured judgments:** suspected data contamination, business context shifts, regulatory interpretation are reserved for humans

Audit artifact guarantees

- HMAC signing:** agent output itself is an audit artifact — HMAC-signed and immutably stored upon generation
- Hash chain:** tamper-proof guarantee via hash chain linked to prior reports
- Human review:** “check when you arrive” model — agent organizes, humans review at their own pace

Airflow DAG Integration

DAG	Agent task	Cadence
dag_drift_monitoring	After drift detection $\rightarrow$ ops_agent_report task appended	Daily
dag_fairness_monitoring	After fairness measurement $\rightarrow$ audit_agent_report task appended	Daily

dag_governance_quarterly	After 36-item check → audit_agent_quarterly report	Quarterly
Training Job completion callback	ops_agent_training_report — training metric analysis	Event-driven

Human-in-the-Loop Design

The Financial-Sector AI Guideline (Auxiliary-Tool principle) requires that **final decisions and accountability rest with staff**. EU AI Act Art. 14 also mandates the same principle. Even when everything is automated, final review is performed by humans.

Design Principle

AI is the tool; final decision authority rests with humans

The PLE-based recommendation system is not “replacing humans” but a tool that “supports human decision-making.” This principle is embedded throughout the system architecture.

Per-Channel Human Oversight Framework

Channel	Human Oversight Method
Offline (Branch)	AI provides recommendation list + rationale on staff screen Final recommendation decision is made by staff judgment Staff reviews rationale and recommends based on customer situation
Online (App/Web)	AI auto-serves recommendation list AI operations team directly controls recommendation direction, targets, and exclusion lists Immediate shutdown via kill switch in emergencies

5 Human Intervention Points

1. Recommendation Rationale Sampling Review

While exhaustive review is infeasible, recommendation rationale outputs are periodically sampled and reviewed for quality, suitability, and regulatory compliance. The recommendation quality monitoring system (L1 rules / L2a rewrite / L2b LLM verification) generates automatic quality metrics, triggering human review on anomaly detection.

2. Model Replacement Approval

The offline Champion-Challenger gate (`ModelCompetition.evaluate`) auto-promotes on statistically significant improvement; bootstrap and emergency rollback are handled via the `--force-promote` operator override. Every decision (`bootstrap` / `promote` / `reject` / `force_promote`) is written by `AuditLogger.log_model_promotion` to an HMAC-signed, hash-chained S3 WORM audit log. A report including replacement rationale, performance comparison, and fairness metrics is generated alongside each promotion, and the operations team performs post-review against the audit chain.

3. Incident Escalation

Auto-detected anomalies (fairness violations, drift, herding) are assessed and acted upon by humans. CRITICAL incidents trigger automatic kill switch activation, followed by human root cause analysis and recovery.

4. Fairness Review

Fairness monitoring results are periodically reviewed by humans. Domain experts provide context-aware interpretation of DI/SPD/EOD auto-measurement results, and decide on threshold adjustments or model retraining as needed.

5. Opt-out and Complaint Handling

Human reprocessing pathways are automatically activated for customer AI decision refusals and complaints. Auto-counselor routing occurs for 7 reason categories, managed under P1(1h)/P2(4h)/P3(24h) SLA.

Human Reprocessing Reason Classification

P1 (Urgent 1 hour)

- Compliance violation detected
- Customer failing suitability check
- Kill switch activation situation

P2 (4 hours) / P3 (24 hours)

- AI decision refusal (opt-out)
- Low-confidence recommendation results
- Explanation supplementation request
- General complaints

Automated Governance Report Generation

Report Framework

Auto-generated on a monthly/quarterly basis, stored in S3, and distributed to the AI Governance Committee.

9-Section Structure

Section	Content	Data Source
1	Fairness summary (DI/SPD/EOD by protected attribute)	FairnessMonitor
2	Drift summary (PSI statistics for the period)	DriftDetector
3	Incident summary (CRITICAL/MAJOR/MINOR counts + details)	IncidentReporter
4	Model change history (training/deployment/rollback)	ExperimentTracker
5	Kill switch history (activation/deactivation counts)	ComplianceAuditStore
6	Recommendation quality (L1/L2 rationale quality metrics)	ReasonQualityMonitor
7	Risk trends (herding trends, risk levels)	HerdingDetector
8	Audit store summary (7 table record counts)	ComplianceAuditStore
9	Executive summary (auto-generated narrative)	Combined

36-Item Regulatory Compliance Auto-Check

A quarterly full check is automatically executed via the 36-item regulatory compliance registry.

Group A (18 Items Implemented)

Model card, training data documentation, safety/trust document
AI disclosure, explainability, opt-out rights
Human review, kill switch, model rollback
Health check, fairness monitoring, suitability constraints, etc.

GAP Group (18 Items Gap Analysis)

Drift auto-response, recommendation rationale quality verification
SLA tracking, EU AI Act high-risk classification
PIA (Privacy Impact Assessment), etc.

Check frequency:

- Daily: Kill switch status, health check
- Weekly: Fairness metrics, explainability
- Quarterly: Full 36-item comprehensive check

3-Tier Governance Framework

Tier 1: Decision — AI Risk Management Committee

AI utilization policy approval, high-impact AI applicability determination, annual impact assessment approval, critical incident reporting framework

Tier 2: Execution — AI Operations Team

Model development and operations, performance monitoring, fairness review, recommendation quality management, incident response

Tier 3: Verification — Internal Audit & Compliance

Independent audit, regulatory compliance verification, impact assessment review, external audit response

Comprehensive Regulatory Mapping

Regulation	Relevant Articles	Design Reflection
AI Basic Act	Art. 31 (AI content labeling)	AI disclosure + recommendation rationale L1/L2
	Art. 33 (high-impact AI governance)	36-item registry + governance report
	Art. 34 (risk management records)	Audit log immutability + 7 audit tables
Financial Consumer Protection Act	Art. 19 (explanation duty)	Feature reverse mapping + per-task interpretation
Financial-Sector AI Guideline 7 principles	① Governance	Risk-assessment system + governance report (●)
	② Legality	36-item law-to-function mapping + regulatory auto-checker (●)
	③ Auxiliary Nature	Offline promotion human gate (●) + HITL queue (●)
	④ Reliability	Training performance metrics (●) + fairness/explainability (●)
	⑤ Financial Stability	Kill switch + drift (PSI) + concentration metrics (●)
	⑦ Security	PII hash (●) + external model/data integrity verification (●)
GDPR	Art. 17 (right to erasure)	30-day PII retention + encrypted deletion
	Art. 22 (automated refusal)	opt_out_audit table

	Art. 35 (DPIA)	PIA gap analysis items
PIPA	Art. 28-2 (pseudonymized data)	Pseudonymization processing record audit
	Art. 37-2 (automated decisions)	Opt-out + human reprocessing
EU AI Act	Art. 13 (transparency)	Recommendation rationale + model card + audit log
	Art. 14 (human oversight)	Kill switch + human reprocessing + per-channel oversight
	Art. 15 (accuracy/security)	Drift detection + prompt injection defense

This document was revised in June 2026 against the FSC Financial-Sector AI Guideline (effective 2026-06-22). The guideline is updated annually after gathering financial-sector input, and this document’s content may also be updated as the companion documents (Financial-Sector AI Risk Management Framework, AI security handbook) and the AI Basic Act subordinate legislation evolve. This material is not a compliance attestation but an architecture-alignment self-check of an Independent Research reference, with implementation status distinguished honestly in three states: ● operational / ● implemented, not wired / ○ absent.

Ops/Audit Agent Integration

All regulatory compliance components documented herein (FairnessMonitor, HerdingDetector, ComplianceChecker, AuditLogger, etc.) are wrapped as tools in the AuditAgent’s 48-item checklist for automated inspection.

A 3-agent consensus mechanism (Sonnet×3 independent voting) structurally mitigates hallucination, and minority reports preserve dissenting opinions. The verdict rule is a deliberate fail-safe: a single FAIL vote escalates to FAIL while PASS requires unanimity, reflecting that in operations and audit a missed risk signal is treated as costlier than a false alarm; and because every dissenting opinion is retained, an auditor can always trace why a minority view was or was not escalated. Diagnostic history accumulates in a LanceDB case store, serving as “continuous improvement evidence” for regulatory audits.

Core design principle: “**AI analyzes, humans decide**” — agents recommend only; final decisions are made by operators. This is designed to align with EU AI Act Art.14 (human oversight), the Financial-Sector AI Guideline’s Auxiliary-Tool principle (human intervention), and AI Basic Act (kill switch).

Detailed design: Design Document 11 (docs/design/11_ops_audit_agent.typ)

Temporal Fact Store (Added 2026-04)

A core audit evidence requirement is “**reproducing system state at a specific point in time**”. Questions like “At 2026-03-15, when customer A received a recommendation, what were the model

version, features, and verdicts?” traditionally require joining across distributed components (AuditLogger, DiagnosticCaseStore, `pipeline_state.json`) — expensive.

We solved this with `TemporalFactStore`, adapted from the Zep/Graphiti pattern. The schema is (`entity`, `attribute`, `value`, `valid_from`, `valid_to`), and most audit queries are **single-entity point-in-time reconstructions** resolvable via native LanceDB filters.

Property	Implementation
No deletion	<code>expire_fact()</code> sets <code>valid_to</code> only, originals preserved
Backend	Shares LanceDB instance with <code>DiagnosticCaseStore</code> (zero new deps)
Z-suffix compat	Normalizes diverse timestamp formats from external callers
Query API	<code>snapshot_at()</code> , <code>get_timeline()</code> , <code>expire_fact()</code>

This is designed to align with EU AI Act Art.12 (record-keeping), the Financial-Sector AI Guideline (audit trail), and AI Basic Act temporal evidence requirements via a single store.